

4 פרק · RED TEAM GUIDES

סיור ו-OSINT

מדריך מלא למתחילים — בעברית

Red Team Guides Series · 2026

פרק 4 — סיור ו-OSINT

מה זה סיור ולמה הוא חשוב?

לפני שתוקפים מחשב, שרת, או ארגון — הם אוספים מידע. הרבה מידע. זה השלב שנקרא **Reconnaissance** (סיור). ככל שיש לתוקף יותר מידע על המטרה, כך גדל הסיכוי שהוא ימצא חולשה. חשבו על זה כמו גנב שמתכנן פריצה לבנק: הוא לא פשוט נכנס דרך הדלת. הוא קודם עוקב אחרי שמירה, סופר מצלמות, מכיר את לוח הזמנים, מבין מי עובד שם. רק אז הוא בא עם תוכנית. ב-red teaming המסלול זהה:

סיור → ניתוח → ניצול → לאחר הכניסה

שני סוגי סיור

סיור פסיבי (Passive Reconnaissance)

מאסוף מידע מבלי לגעת ישירות במטרה. המטרה לא מרגישה כלום — כי אנחנו לא שולחים אליה ולו חבילה אחת. אנחנו קוראים מה שכבר פומבי. דוגמאות: חיפוש ב-Google, קריאת WHOIS, בדיקת LinkedIn, הסתכלות על GitHub.

סיור אקטיבי (Active Reconnaissance)

מתקשרים ישירות עם המטרה — שולחים חבילות, שואלים שאלות, סורקים פורטים. לאמצעים המתוחכמים המטרה עשויה לזהות אנחנו. דוגמאות: nmap, DNS zone transfer, ping, nikto.

OSINT (Open Source Intelligence) = מודיעין ממקורות פתוחים. כל המידע שכבר קיים ברשת — פומבי, חינוכי — ואנחנו רק צריכים לדעת איפה לחפש.

חלק 1: Google Dorks — איך Google הופך לנשק

מרבית האנשים מחפשים ב-Google מילים בודדות. אבל ל-Google יש מפעילים (operators) מתקדמים שמאפשרים חיפוש מדויק מאוד — ועם זה, לגלות מידע שאחרים לא ידעו שהוא גלוי.

המפעילים החשובים

מפעיל	משמעות	דוגמה
site:	רק מאתר מסוים	site:example.com
filetype:	סוג קובץ	filetype:pdf confidential
intitle:	מה שמופיע בכותרת הדף	intitle:"index of"
inurl:	מה שמופיע ב-URL	inurl:admin
intext:	מה שמופיע בגוף הדף	intext:"password"
cache:	גרסה שמורה ב-Google	cache:example.com
"..."	ביטוי מדויק	"internal use only"
-	לא לכלול מילה	site:example.com -www
OR	אחד מהשניים	site:example.com OR site:sub.example.com

Google Dorks מעשיים

מציאת קבצים רגישים:

```
# קבצי Excel/Word עם "confidential" מאתר ספציפי
site:example.com filetype:xlsx confidential
site:example.com filetype:docx "internal use only"

# PDF עם credentials
filetype:pdf "username" "password" site:example.com

# גיבויים חשובים
site:example.com filetype:bak OR filetype:sql OR filetype:zip

# קבצי config
filetype:env "DB_PASSWORD"
filetype:cfg "password"
filetype:ini "password"
```

מציאת לוחות מחוונים וממשקי ניהול:

```
# phpMyAdmin
intitle:"phpMyAdmin" inurl:/phpmyadmin/
```

```
# Webcam streams
intitle:"webcamXP 5" inurl:8080
```

```
# Jenkins (CI/CD)
intitle:"Dashboard [Jenkins]"
```

```
WordPress של בקרה #
inurl:/wp-admin/ site:example.com
```

```
# Kibana dashboard
intitle:"Kibana" inurl:5601
```

```
# Grafana
intitle:"Grafana" inurl:3000
```

מציאת גרסאות פגיעות:

```
# Apache version זקן
intitle:"Apache/2.2" intitle:"Server at"
```

```
# IIS חשוף
intitle:"IIS Windows Server"
```

```
# PHP errors (דו"ח שגיאות)
"PHP Parse error" OR "PHP Warning" OR "PHP Fatal error" site:example.com
```

מציאת login pages:

```
site:example.com inurl:login
site:example.com inurl:signin
site:example.com intitle:"Sign In"
site:example.com intitle:"Login"
```

מציאת subdirectories חשופים:

```
# Index of – תיקיות פתוחות
intitle:"Index of/" site:example.com
intitle:"index of" "parent directory" site:example.com
```

מציאת email addresses:

```
site:example.com "@example.com" filetype:pdf OR filetype:docx
"@example.com" site:linkedin.com
```

GHDB — Google Hacking Database

קיים אתר שלם שאוסף Google Dorks שנמצאו בעבר: exploit-db.com/google-hacking-database. שם תמצאו אלפי dorks מסווגים לפי קטגוריה — cameras, passwords, vulnerable servers.

חלק 2: WHOIS ו-DNS — מי הבעלים של הדומיין

WHOIS — מי רשם את הדומיין

כל דומיין ברשת נרשם ב-registrar (חברת רישום). בזמן הרישום, הבעלים צריך למסור מידע — שם, כתובת, אימייל, טלפון. חלק ממידע זה פומבי ונשמר ב-WHOIS.

```
# בדיקת WHOIS
whois example.com

# פלט דוגמה:
# Domain Name: EXAMPLE.COM
# Registrar: ICANN
# Registrar IANA ID: 376
# Creation Date: 1995-08-14T04:00:00Z
# Registry Expiry Date: 2023-08-13T04:00:00Z
# Name Server: A.IANA-SERVERS.NET
# Name Server: B.IANA-SERVERS.NET
# Registrant Email: whois@iana.org
```

מה מחפשים ב-WHOIS:

- **Creation Date**: מתי נרשם הדומיין — דומיינים חדשים יכולים להיות phishing
- **Name Servers**: שרתי ה-DNS — אפשר לגלות ספקים
- **Registrant Info**: אם לא מוסתר, אימייל ומידע על הבעלים

אתרים אלטרנטיביים:

- whois.domaintools.com — ממשק גרפי
- lookup.icann.org — הכי מדויק
- WHOIS — viewdns.info + כלים נוספים

Reverse WHOIS — מי עוד אצל אותו בעלים

אם מצאתם שם או אימייל של הארגון ב-WHOIS, אפשר לחפש אילו דומיינים נוספים רשומים לאותו אדם/ארגון:

- viewdns.info/reversewhois/
- domaintools.com/research/reverse-whois/

DNS Enumeration — מציאת תת-דומיינים

כל ארגון גדול יש לו עשרות ואף מאות, mail.example.com, vpn.example.com, subdomain: dev.example.com. כל אחד מהם יכול להיות נקודת כניסה.

dig — שאלות DNS ידניות:

```
# כתובת IP של דומיין (A record)
dig example.com A

# MX records (שרתי מיל)
dig example.com MX

# TXT records (SPF, DKIM, verification codes)
dig example.com TXT

# NS records (שרתי DNS)
dig example.com NS

# SOA record
dig example.com SOA

# שאילתה לשרת DNS ספציפי
dig @8.8.8.8 example.com A

# AAAA record (IPv6)
dig example.com AAAA

# CNAME record
dig www.example.com CNAME

# כל ה-records
dig example.com ANY
```

Zone Transfer — השגת רשימת כל ה-DNS records:

```
# ניסיון zone transfer (מתקפה פסיבית לגבי DNS)
dig axfr @ns1.example.com example.com

# אם מצליח – מקבלים את כל ה-records:
# example.com.      86400 IN SOA ns1.example.com. ...
# mail.example.com. IN A 1.2.3.4
# vpn.example.com.  IN A 1.2.3.5
# dev.example.com.  IN A 1.2.3.6
```

Zone Transfer אמור להיות מוגבל רק לשרתי DNS מורשים. אם ה-DNS לא מוגדר נכון, כל אחד יכול לקבל את הרשימה.

nslookup — אלטרנטיבה ל-dig:

```
nslookup example.com
nslookup -type=mx example.com
nslookup -type=ns example.com
```

חלק 3: כלי Subdomain Enumeration

Subfinder

subfinder הוא כלי מהיר שמחפש subdomains ממקורות פסיביים — Certificate Transparency logs, APIs של VirusTotal, Censys, Shodan, ועוד.


```
# התקנה
go install -v github.com/projectdiscovery/subfinder/v2/cmd/subfinder@latest
(Kali: sudo apt install subfinder-ב) #

# חיפוש בסיסי
subfinder -d example.com

# פלט לקובץ
subfinder -d example.com -o subdomains.txt

# יותר מקורות
subfinder -d example.com -all

# verbose
subfinder -d example.com -v
```

Amass — הכי עמוק

amass הוא הכלי הכי מקיף ל-sub-domain enumeration — משתמש ב-DNS bruteforce, certificate transparency, passive APIs ועוד.

```
# התקנה
sudo apt install amass

# פסיבי enumeration
amass enum -passive -d example.com

# enumeration אקטיבי (DNS bruteforce)
amass enum -active -d example.com

# שמירה לקובץ
amass enum -d example.com -o amass_output.txt

# מיפוי מלא עם visualization
amass enum -d example.com -json amass.json
```

dnsx — אימות ופתרון DNS

אחרי שיש לנו רשימת subdomains, אנחנו צריכים לדעת אילו מהם בכלל קיימים (מפנים לכתובת IP).

```
# התקנה
go install -v github.com/projectdiscovery/dnsx/cmd/dnsx@latest

# אימות מרשימת subdomains
cat subdomains.txt | dnsx

# פתרון ל-IP
cat subdomains.txt | dnsx -resp

# בלבד A records
cat subdomains.txt | dnsx -a
```

Workflow מלא של Subdomain Enumeration

```
# שלב 1: subfinder
subfinder -d example.com -o step1.txt

# שלב 2: amass
amass enum -passive -d example.com -o step2.txt

# שלב 3: מיזוג ואיחוד
cat step1.txt step2.txt | sort -u > all_subs.txt
wc -l all_subs.txt # נמצאו subdomain כמה

# שלב 4: אימות מי חי
cat all_subs.txt | dnsx -resp | tee live_subs.txt

# שלב 5: מציאת web servers
cat live_subs.txt | httpx -status-code -title -tech-detect
```

Certificate Transparency — מאגר זהב

כל תעודת TLS/SSL שמונפקת לאתר נרשמת ב-Certificate Transparency logs — מאגר פומבי ושקוף לחלוטין. זה מאפשר לנו לראות את כל ה-subdomains שהארגון ביקש תעודות עבורם, כולל דברים שהם לא רצו שתדעו.

```
# אתרים לחיפוש:
# crt.sh – פשוט
curl "https://crt.sh/?q=%example.com&output=json" | jq '.[].name_value' | sort -u

# certspotter
curl "https://api.certspotter.com/v1/issuances?domain=example.com&include_subdomains=true"
```

חלק 4: Shodan — ה-Google של ה-IoT והמכונות

Shodan הוא מנוע חיפוש מיוחד שסורק את כל האינטרנט ומאנדקס מה שמחשבים מחזירים כשמתחברים אליהם. בניגוד ל-Google שמאנדקס דפי אינטרנט, Shodan מאנדקס **שירותים** — פורטים פתוחים, באגרים, מידע על מערכת הפעלה.

מה Shodan מוצא

- שרתי SSH, FTP, Telnet, HTTP
- מצלמות רשת חשופות
- נתבים עם ממשק ניהול פתוח
- מערכות SCADA ו-ICS (מפעלים, חשמל)
- מסדי נתונים חשופים (MongoDB, Elasticsearch)
- מכשירי IoT (מדפסות, מזגנים, מנעולים)

Shodan CLI התקנת #

```
pip3 install shodan
```

```
shodan init YOUR_API_KEY
```

חיפוש בסיסי #

```
shodan search "apache"
```

חיפוש לפי ארגון #

```
shodan search "org:example corporation"
```

חיפוש לפי מדינה #

```
shodan search "country:IL apache"
```

פילטרים ב-Shodan search:

לפי ארגון

org:"Company Name"

לפי מדינה

country:US

country:IL

לפי עיר

city:"Tel Aviv"

לפי פורט

port:22

port:3389

לפי hostname

hostname:example.com

לפי מוצר

product:"Apache httpd"

product:"nginx"

product:"Microsoft IIS"

לפי גרסה

version:"2.4.49"

לפי מערכת הפעלה

os:"Windows Server 2016"

לפי vulnerability (CVE)

vuln:CVE-2021-44228

לפי TLS certificate

ssl:"example.com"

ssl.cert.subject.cn:"example.com"

מסדי נתונים חשופים

product:MongoDB port:27017

product:Elasticsearch port:9200

```
# מצלמות Webcam חשופות  
title:"webcam" has_screenshot:true
```

```
# פאנלי ניהול של Cisco  
"IOS" "CISCO" port:80
```

```
# Elasticsearch (ללא אימות) פתוח  
product:"Elastic" port:9200
```

```
# RDP (Remote Desktop) חשוף  
port:3389 os:"Windows"
```

```
# Telnet (פרוטוקול ישן ולא מוצפן)  
port:23 "login"
```

```
# כלי ניהול מרחוק  
port:5900 "VNC"
```

```
# שרתי FTP עם login anonymous  
port:21 "230 Anonymous"
```

```
# phpMyAdmin חשוף  
http.title:"phpMyAdmin" port:80
```

```
# Jenkins ללא הרשאות  
http.title:"Dashboard [Jenkins]"
```

```
# Redis ללא סיסמה  
product:"Redis" port:6379
```

```
# Kibana  
http.title:"Kibana" port:5601
```

```
import shodan

api = shodan.Shodan('YOUR_API_KEY')

# חיפוש
results = api.search('apache org:"Example Corp"')

print(f"תוצאות {results['total']} נמצאו")

for result in results['matches']:
    print(f"IP: {result['ip_str']}")
    print(f"Port: {result['port']}")
    print(f>Data: {result['data'][:100]}")
    print("---")

# מידע על IP ספציפי
host = api.host('1.2.3.4')
print(host['org'])
print(host['ports'])
```

Censys — אלטרנטיבה ל-Shodan

Censys דומה ל-Shodan אבל עם דגש על certificates ו-TLS:

```
# חיפוש ב-Censys
pip3 install censys

censys search "example.com" --index certificates
censys search "ports.443.https.tls.certificate.parsed.names: example.com"
```

Shodan ו-Certificates

אחת הדרכים הטובות ביותר למצוא IPs של ארגון — חיפוש certificate:

```
ssl.cert.subject.cn:"example.com"
ssl.cert.subject.o:"Example Corporation"
```


חלק 5: theHarvester — מציאת אימיילים ועוד

theHarvester הוא כלי שאוסף:

- כתובות אימייל
- שמות עובדים
- subdomains
- כתובות IP

ממקורות שונים: Google, Bing, LinkedIn, Shodan, ועוד.

```
# הרצה בסיסית (מ-Kali, כבר מותקן)
theHarvester -d example.com -b google

# מקורות שונים
theHarvester -d example.com -b bing
theHarvester -d example.com -b linkedin
theHarvester -d example.com -b shodan

# כל המקורות
theHarvester -d example.com -b all

# שמירה לקובץ
theHarvester -d example.com -b all -f results.html

# הגבלת תוצאות
theHarvester -d example.com -b google -l 200
```

דוגמת פלט:

```
[*] Emails found:
john.doe@example.com
jane.smith@example.com
admin@example.com

[*] Hosts found:
mail.example.com - 1.2.3.4
vpn.example.com - 1.2.3.5
www.example.com - 1.2.3.6

[*] IPs found:
1.2.3.4
1.2.3.5
```

חלק 6: Recon-ng — מסגרת OSINT מלאה

Recon-ng הוא כמו Metasploit — אבל לreconnaissance. מסגרת עבודה עם modules, workspace, database, ו-reporting.

הפעלה

recon-ng

יצירת workspace

```
[recon-ng] > workspaces create example_com
```

הכנסת הדומיין

```
[recon-ng] > db insert domains example.com
```

חיפוש modules

```
[recon-ng] > marketplace search whois
```

```
[recon-ng] > marketplace search shodan
```

התקנת module

```
[recon-ng] > marketplace install recon/domains-hosts/google_site_web
```

שימוש ב-module

```
[recon-ng] > modules load recon/domains-hosts/google_site_web
```

```
[recon-ng] > run
```

הצגת תוצאות

```
[recon-ng] > show hosts
```

```
[recon-ng] > show contacts
```

```
[recon-ng] > show credentials
```

ייצוא דוח

```
[recon-ng] > modules load reporting/html
```

```
[recon-ng] > options set FILENAME report.html
```

```
[recon-ng] > run
```

```
# WHOIS ל-domains
recon/domains-contacts/whois_pocs

# Google לsub-domains
recon/domains-hosts/google_site_web

# Bing לsub-domains
recon/domains-hosts/bing_domain_web

# Shodan לsub-domains
recon/domains-hosts/shodan_hostname

# Certificate transparency
recon/domains-hosts/certificate_transparency

# LinkedIn profiles
recon/companies-contacts/linkedin_crawl

# HaveIBeenPwned – דליפות
recon/contacts-credentials/hibp_email
```

חלק 7: OSINT על אנשים — LinkedIn, GitHub, רשתות חברתיות

LinkedIn OSINT

LinkedIn הוא מטמון של מידע על עובדים בארגון:

- שמות עובדים
- תפקידים
- מחלקות
- כישורים ותכונות שעובדים יודעים (מגלה stack הטכנולוגי)
- היסטוריית עבודה

מה לחפש ב-LiNKedIn:

```
# חיפוש עובדים של חברה
```

```
"Company Name" site:linkedin.com/in
```

```
# חיפוש roles ספציפיים
```

```
"Company Name" "DevOps Engineer" site:linkedin.com/in
```

```
"Company Name" "Security" site:linkedin.com/in
```

```
"Company Name" "Network Administrator" site:linkedin.com/in
```

מה אפשר ללמוד:

- DevOps engineer שעובד עם AWS + Kubernetes + Terraform = ארגון עם AWS cloud
- Security engineer שמזכיר "CrowdStrike" = הם משתמשים ב-EDR זה
- אדם שעזב לאחרונה = לפעמים חושף מידע ב-LinkedIn post

GitHub OSINT

GitHub הוא מקור מידע עצום. מפתחים לפעמים מעלים קוד עם:

- API keys וסיסמאות בקוד
- Connection strings לבסיסי נתונים
- קבצי config עם מידע רגיש
- לוגים ומידע על infra פנימית

חיפוש ב-GitHub:

```
# חיפוש ב-GitHub UI
```

```
"example.com" "password"
```

```
"@example.com" api_key
```

```
"example.com" "secret"
```

```
"example.com" "BEGIN RSA PRIVATE KEY"
```

```
# חיפוש קוד ספציפי
```

```
"example.com" language:python "import boto3" # AWS SDK
```

```
"example.com" language:yml "password:"
```

כלי אוטומטי — GitDorker:

```
python3 gitdorker.py -tf TOKENSFILE -q example.com -d dorks/BHUSA.txt
```

truffleHog — חיפוש secrets ב-git history:

```
# התקנה
pip3 install trufflehog

# סריקת repository
trufflehog git https://github.com/example/repo

# כולל history
trufflehog git https://github.com/example/repo --since-commit HEAD~50
```

GitHub Recon מעשי

```
# חיפוש organizations ב-GitHub
curl "https://api.github.com/orgs/example-corp/repos" | jq '.[].name'

# חיפוש users של ארגון
curl "https://api.github.com/orgs/example-corp/members" | jq '.[].login'

# חיפוש public repositories של user
curl "https://api.github.com/users/john.doe/repos" | jq '.[].name'
```

Twitter/X OSINT

מציאת מידע דרך Twitter/X:

```
# חיפוש עובדים  
"example.com" OR "@ExampleCorp" site:twitter.com
```

```
# מציאת credentials בטעות  
"example.com" "password" site:twitter.com
```

```
# ב-Twitter search  
from:examplecorp -filter:retweets
```

```
# (Google) ישנים Tweets  
site:twitter.com "example.com" "password"
```

Wayback Machine — Archives של אתרים

archive.org שומר snapshot של אתרים לאורך שנים. שימושי ל:

- ראיית תוכן שנמחק
- מציאת endpoints ישנים
- הבנת ה-stack הטכנולוגי בעבר

```
# בדיקת archive  
curl "http://archive.org/wayback/available?url=example.com"
```

```
# ישנים URLs כלי לאיסוף – waybackurls  
go install github.com/tomnomnom/waybackurls@latest  
waybackurls example.com | tee wayback.txt
```

```
# ניתוח URLs ישנים  
cat wayback.txt | grep -E "\.(php|asp|aspx|jsp)$" # pages עם back-end  
cat wayback.txt | grep -E "admin|login|api"      # מעניינות pages  
cat wayback.txt | grep "?.*="                  # parameters
```

חלק 8: Email Enumeration

מציאת פורמט אימייל

אחרי שמצאנו שמות עובדים, צריך להבין את פורמט האימייל:

```
john.doe@example.com    → firstname.lastname
jdoe@example.com        → firstinitiallastname
j.doe@example.com       → firstinitial.lastname
doej@example.com        → lastnamefirstinitial
john@example.com        → firstname only
```

כלים לבדיקת פורמט:

```
# Hunter.io API
curl "https://api.hunter.io/v2/domain-search?domain=example.com&api_key=YOUR_KEY"

# ה-API מחזיר:
# {"data": {"emails": [{"value": "john@example.com", "type": "personal"}]}}
```

SMTP User Enumeration

SMTP (פרוטוקול שליחת מייל) לפעמים מאפשר לשאול אם כתובת מייל קיימת:

```
# התחברות ל-SMTP
nc mail.example.com 25

# VRFY – user בדיקה אם
VRFY john.doe

# EXPN – הרחבת alias
EXPN support

# RCPT TO – בדיקה דרך המצאות
MAIL FROM: test@test.com
RCPT TO: john.doe@example.com
```

:smtp-user-enum


```
sudo apt install smtp-user-enum
```

```
usernames # בדיקת רשימת
```

```
smtp-user-enum -M VRFY -U usernames.txt -t mail.example.com
```

```
RCPT # עם
```

```
smtp-user-enum -M RCPT -U emails.txt -t mail.example.com
```

חלק 9: Maltego — ויזואליזציה של OSINT

Maltego הוא כלי גרפי שמציג את הקשרים בין ישויות שונות (domains, IPs, אימיילים, אנשים) בצורה ויזואלית.

```
# ב-Kali כבר מותקן
```

```
maltego
```

Transforms — פעולות ב-Maltego:

1. גוררים entity (דומיין)
2. לוחצים ימני → Run Transforms
3. בוחרים transform (מה לחפש)
4. Maltego מציג תוצאות גרפית

Entities נפוצות:

- Domain → DNS Names (subdomains)
- Domain → IP Addresses
- Email → Person (LinkedIn)
- IP → Organization (ASN)
- Person → Social Networks

חלק 10: ASN ו-IP Ranges של ארגון

כל ארגון גדול יש לו ASN (Autonomous System Number) — מספר שמזהה את הרשת שלהם באינטרנט. ממנו אפשר למצוא את כל כתובות ה-IP שלהם.

מציאת ASN

```
# בדיקת ASN לפי שם ארגון
# חיפוש חינומי → bgp.he.net
curl "https://api.bgpview.io/search?query_term=Example+Corporation"

# IP לפי whois
whois 1.2.3.4

# נכלל ב-whois output:
# Organization: Example Corp (EXMPL-1)
# ASN: AS12345
```

מציאת IP ranges לפי ASN

```
# באמצעות bgp.he.net
curl "https://api.bgpview.io/asn/12345/prefixes"

# פלט: רשימת CIDR ranges של הארגון
# "1.2.3.0/24"
# "10.20.0.0/16"

# ranges-לכלל ה-nmap
sudo nmap -sn 1.2.3.0/24 10.20.0.0/16
```

```
curl ipinfo.io/1.2.3.4
```

```
# פלט:
```

```
# {  
#   "ip": "1.2.3.4",  
#   "org": "AS12345 Example Corporation",  
#   "country": "IL",  
#   "city": "Tel Aviv"  
# }
```

חלק 11: Web Technologies Fingerprinting

לפני שתוקפים web application, צריך לדעת עם מה הוא בנוי.

Wappalyzer

Wappalyzer הוא extension לדפדפן שמזהה טכנולוגיות של אתר אוטומטית:

- Framework: React, Vue, Angular, jQuery
- Server: Apache, nginx, IIS
- CMS: WordPress, Drupal, Joomla
- Language: PHP, Python, Node.js
- Database: MySQL, MongoDB

whatweb — זיהוי מהשורה

```
sudo apt install whatweb
```

```
whatweb example.com
```

```
whatweb -v example.com # verbose
```

```
whatweb -a 3 example.com # aggressive
```

```
# פלט:
```

```
# http://example.com [200 OK] Apache[2.4.41], PHP[7.4.3], WordPress[5.8]
```

```
# HTTP headers
curl -I http://example.com

# מגלה מידע:
# Server: Apache/2.4.41 (Ubuntu)
# X-Powered-By: PHP/7.4.3
# Set-Cookie: PHPSESSID=... (→ PHP)
# X-Generator: WordPress 5.8

# robots.txt – לפעמים חושף directories
curl http://example.com/robots.txt

# sitemap.xml
curl http://example.com/sitemap.xml
```

httpx — סריקת web servers מהירה

```
go install -v github.com/projectdiscovery/httpx/cmd/httpx@latest

# סריקה של רשימת hosts
cat live_subs.txt | httpx

# עם מידע נוסף
cat live_subs.txt | httpx -status-code -title -tech-detect -content-length

# פלט:
# https://admin.example.com [200] [Admin Panel] [Apache,PHP,WordPress] [45231]
# https://dev.example.com [200] [Dev Environment] [nginx,Python] [12389]
# https://api.example.com [200] [API Gateway] [nginx] [342]
```

חלק 12: מיפוי המטרה — Attack Surface Map

בסוף reconnaissance, כדאי לאסוף את כל מה שמצאנו למסמך אחד:

=== ATTACK SURFACE MAP — example.com ===

DOMAINS & SUBDOMAINS:

- example.com → 1.2.3.4 (Apache 2.4.41, PHP 7.4.3, WordPress 5.8)
- www.example.com → 1.2.3.4
- mail.example.com → 1.2.3.5 (Exchange 2019)
- vpn.example.com → 1.2.3.6 (Cisco AnyConnect)
- dev.example.com → 10.20.30.40 (nginx, Django)
- admin.example.com → 1.2.3.4/admin (login page)
- api.example.com → 1.2.3.7 (REST API)

EMAILS FOUND:

- john.doe@example.com (CTO - from LinkedIn)
- jane.smith@example.com (DevOps - from GitHub)
- admin@example.com (from website footer)

EMPLOYEES (LinkedIn):

- CTO: John Doe (AWS, Kubernetes, Terraform)
- DevOps: Jane Smith (Jenkins, Docker, GitHub)
- Security: Mike Cohen (CrowdStrike, Splunk)

TECHNOLOGY STACK:

- Cloud: AWS (from LinkedIn profiles)
- CMS: WordPress 5.8 (outdated — CVE-2022-21661)
- Email: Microsoft Exchange 2019
- VPN: Cisco AnyConnect
- CI/CD: Jenkins (from Jane Smith profile)

INTERESTING FINDINGS:

- dev.example.com accessible from internet (should be internal)
- GitHub: found AWS key in old commit (repo: john-doe/scripts)
- WordPress 5.8 vulnerable to SQL injection (CVE-2022-21661)
- VPN on 1.2.3.6 — port 443 open

OPEN PORTS (from Shodan):

- 1.2.3.4: 80, 443, 8080
- 1.2.3.5: 25, 80, 443, 587

- 1.2.3.6: 443, 4443
- 1.2.3.7: 80, 443, 8443

חלק 13: כלי OSINT נוספים

SpiderFoot

SpiderFoot הוא כלי OSINT אוטומטי שמריץ מאות modules ומציג תוצאות ב-web UI.

```
# התקנה
pip3 install spiderfoot

# הרצה עם web UI
spiderfoot -l 127.0.0.1:5001

# פתיחת דפדפן: http://127.0.0.1:5001
```

Metagoofil — חילוץ מטאדטה מקבצים

מסמכים (PDF, Word, Excel) מכילים מטאדטה שיכולה לחשוף:

- שמות משתמשים
- שמות מחשבים
- תוכנות ששימשו ליצירת הקובץ

```
sudo apt install metagoofil

# הורדה וניתוח קבצים מ-Google
metagoofil -d example.com -t pdf,docx,xlsx -l 20 -o output/

# ניתוח קובץ ספציפי
exiftool document.pdf
exiftool document.docx
```

```
# יצירת alert – קבלת התראה כשמשהו חדש מופיע
shodan alert create "example.com" "net:1.2.3.0/24"

# הצגת alerts קיימים
shodan alert list
```

Have I Been Pwned — דליפות נתונים

```
# בדיקת אימייל בדליפות
curl "https://haveibeenpwned.com/api/v3/breachedaccount/john@example.com" \
-H "hibp-api-key: YOUR_KEY"

# בדיקת domain
curl "https://haveibeenpwned.com/api/v3/breaches?domain=example.com"
```

Hunter.io

```
# חיפוש אימיילים לפי domain
curl "https://api.hunter.io/v2/domain-search?domain=example.com&api_key=YOUR_KEY"

# בדיקת אימייל ספציפי
curl "https://api.hunter.io/v2/email-verifier?email=john@example.com&api_key=YOUR_KEY"
```

חלק 14: OSINT בלי להשאיר עקבות

כשעושים OSINT — במיוחד סיור פסיבי — כדאי להזהר:

כיצד אתרים מזהים אתכם:

1. כתובת IP
2. User-Agent (איזה דפדפן/כלי)
3. Cookies ו-fingerprinting
4. Rate limiting (יותר מדי בקשות)

```
# שינוי User-Agent
curl -A "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36" https://example.co

# דרך TOR
torify curl https://example.com

# VPN
# חיבור ל-VPN לפני כל פעולה

# proxychains
proxychains curl https://example.com

# Delays בין בקשות
# לא לשלוח 1000 בקשות בשניה אחת
for domain in $(cat domains.txt); do
    curl https://$domain
    sleep $((RANDOM % 5 + 1)) # המתנה 1-5 שניות
done
```

כלי VPN לחוקרים:

- Mullvad VPN (לא דורש אימייל)
- ProtonVPN (תוכנית חינמית)

חלק 15: Passive DNS — היסטוריית DNS

מה זה Passive DNS?

כשמחשבים ברחבי האינטרנט שואלים "מה ה-IP של example.com?", חלק מהשאלות הללו נרשמות. זה יוצר מסד נתונים של הקשרים ההיסטוריים בין domains ל-IPs.

למה זה שימושי?

- מציאת IP ישן שעדיין פעיל (CDN הסתיר את ה-IP האמיתי)
- מציאת domains אחרים שהיו על אותו IP


```
# SecurityTrails (API)
curl "https://api.securitytrails.com/v1/history/example.com/dns/a" \
  -H "APIKEY: YOUR_KEY"

# VirusTotal passive DNS
curl "https://www.virustotal.com/api/v3/domains/example.com/resolutions" \
  -H "x-apikey: YOUR_KEY"

# Farsight DNSDB
# (שירות בתשלום אבל מהטובים)
```

חלק 16: BGP Analysis ו-IP Geolocation

```
# מידע מפורט על IP
curl ipinfo.io/1.2.3.4

# BGP routing מידע על – BGP
curl "https://api.bgpview.io/ip/1.2.3.4"

# whois prefixes
whois -h whois.radb.net 1.2.3.0/24

# Hurricane Electric BGP Toolkit
# bgp.he.net – ממשק גרפי מצוין
```

סיכום — Workflow OSINT מלא

כך נראה תהליך OSINT מלא על ארגון:

```
=== WHOIS :1 שלב === #
whois example.com
# → מ'י הבעלים, name servers, תאריכים

=== DNS :2 שלב === #
dig example.com ANY
dig example.com MX
dig example.com TXT
# → mail servers, SPF, DKIM, verification records

=== Sub-domains :3 שלב === #
subfinder -d example.com -o subs1.txt
amass enum -passive -d example.com -o subs2.txt
cat subs1.txt subs2.txt | sort -u > all_subs.txt
cat all_subs.txt | dnsx -resp > live_subs.txt

=== Web Tech :4 שלב === #
cat live_subs.txt | httpx -status-code -title -tech-detect

=== Google Dorks :5 שלב === #
# site:example.com filetype:pdf confidential
# site:example.com inurl:admin
# site:example.com intitle:"Index of"

=== Shodan :6 שלב === #
shodan search "org:\"Example Corporation\""
shodan search "ssl:example.com"

=== theHarvester :7 שלב === #
theHarvester -d example.com -b all -f harvest.html

=== GitHub :8 שלב === #
GitHub-ב "example.com" "password" חיפוש #
trufflehog git https://github.com/example-corp/public-repo

=== Wayback Machine :9 שלב === #
waybackurls example.com > wayback.txt
```

```
=== # שלב 10: מיפוי  
# כתיבת attack surface map
```

בפרק הבא נלמד **Network Pentesting** — איך להשתמש במידע שאספנו כדי להתחיל לבדוק פגיעויות בפועל.